

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-NYDFS-01

NYDFS Part 500 Explained

A Comprehensive Overview of New York's Cybersecurity Regulation for Financial Institutions

TSEC Compliance Insights | NYDFS Series

Document ID:	GUIDE-NYDFS-01
Version:	2026 Edition
Effective Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

1. What Is NYDFS Part 500?

23 NYCRR Part 500 — known as the NYDFS Cybersecurity Regulation — is a comprehensive set of cybersecurity requirements promulgated by the New York State Department of Financial Services (NYDFS) that applies to financial institutions operating in New York State. First adopted in 2017 as the first regulation of its kind in the United States, Part 500 underwent significant amendment in November 2023, adding new requirements for governance, incident reporting, and technology controls. The regulation covers insurers, banks, mortgage companies, money transmitters, and other financial services providers licensed or authorized by the New York Department of Financial Services.

2. Who Is a 'Covered Entity'?

A Covered Entity under Part 500 is any person operating under or required to operate under a license, registration, charter, certificate, permit, or similar authorization under the Banking Law, Insurance Law, or Financial Services Law. This includes, among others: New York-chartered banks and trust companies; licensed mortgage bankers and servicers; licensed money transmitters; insurance companies and insurance agents licensed in New York; premium finance companies; and budget planners.

Part 500 provides for limited exemptions. Small entities meeting certain thresholds (fewer than 10 employees, under \$5M in gross annual revenue, or under \$10M in total assets) are exempt from most requirements, though they must still notify NYDFS of their exemption.

3. The Core Requirements of Part 500

Section	Requirement	Key Points
500.2	Cybersecurity Program	Maintain a cybersecurity program designed to protect Information Systems and Nonpublic Information, performing core functions: identify, protect, detect, respond, recover
500.3	Cybersecurity Policy	Written policy approved at least annually by the Senior Governing Body or a Senior Officer, covering 14 specified policy areas
500.4	CISO and Governance	Designate a qualified CISO; CISO must report in writing at least annually to the Senior Governing Body on the cybersecurity program and material risks
500.5	Penetration Testing & Vulnerability Assessments	Continuous monitoring or annual penetration testing plus bi-annual vulnerability assessments; informed by the Risk Assessment
500.7	Access Privileges	Limit user access privileges; periodically review; limit and monitor privileged accounts; review access quarterly
500.8	Application Security	Written application security procedures for software developed in-house
500.9	Risk Assessment	Periodic risk assessment with documented criteria; used to inform cybersecurity policy and controls
500.10	Cybersecurity Personnel	Sufficient cybersecurity personnel and threat intelligence capabilities
500.11	Third Party Service Providers	Policies for security of Nonpublic Information held by third parties; minimum cybersecurity practices required of vendors; periodic assessment

500.12	Multi-Factor Authentication	MFA for remote access to Information Systems, privileged accounts, and third-party applications containing Nonpublic Information
500.13	Data Retention Limitations	Secure disposal of Nonpublic Information when no longer necessary; policies on retention
500.14	Training and Monitoring	Train personnel; monitor user activity; detect unauthorized access to Nonpublic Information
500.15	Encryption	Encrypt Nonpublic Information in transit over external networks and at rest; documented compensating controls if encryption is infeasible
500.16	Incident Response Plan	Written IRP covering response, recovery, communication, documentation, and evaluation
500.17	Notification Requirements	Notify NYDFS Superintendent within 72 hours of a Notification Event; file annual certification of compliance; 5-year record retention

4. The 2023 Amendments: What Changed?

The 2023 amendments to Part 500 significantly strengthened governance, incident notification, and technology control requirements. Key changes include:

- Expanded governance requirements: The Senior Governing Body must now have 'sufficient understanding' of cybersecurity risk management and ensure executives report to it periodically on material risks (not just annually)
- Faster incident notification: Ransomware attacks and events involving deployment of ransomware on material systems now trigger the 72-hour notification requirement, alongside other notification events
- Ransomware extortion payment reporting: Organizations making extortion payments must notify NYDFS within 24 hours and provide a written explanation within 30 days
- New technology controls: New requirements for endpoint detection and response (EDR), privileged access management (PAM) solutions, and network security controls for larger Covered Entities
- Annual penetration testing: Clarified requirement for annual penetration testing regardless of whether continuous monitoring is deployed
- Class A companies: Large Covered Entities (500+ employees or \$10B+ revenue) face additional requirements

5. The 72-Hour Notification Requirement in Detail

One of the most operationally significant requirements of Part 500 is the 72-hour notification obligation. A Covered Entity must notify the Superintendent as promptly as possible, but in no event later than 72 hours from a determination that a Notification Event has occurred. A Notification Event is:

- A Cybersecurity Event that impacts the Covered Entity of a type that requires notice to be provided to any government body, self-regulatory agency, or other supervisory body
- A Cybersecurity Event that has a reasonable likelihood of materially harming any material part of the normal operation(s) of the Covered Entity
- A Cybersecurity Event involving unauthorized access to privileged accounts

- A Cybersecurity Event resulting in the deployment of ransomware within a material part of the Covered Entity's Information Systems

The 72-hour clock starts from the determination that a Notification Event has occurred — not from discovery of the underlying incident. This means the CISO must make a prompt determination once an incident is identified, involving Legal Counsel as appropriate.

6. Annual Certification

Each Covered Entity must submit an annual certification to the Superintendent confirming material compliance with Part 500 during the prior calendar year — or, where material compliance was not achieved, an acknowledgment identifying the non-compliant sections and a remediation plan. The certification is signed by the Senior Governing Body and the CISO. Filing is made via the NYDFS online portal.

7. Key Takeaways

- Part 500 is the most detailed state-level cybersecurity regulation in the US, and the 2023 amendments significantly expanded its requirements
- The 72-hour notification requirement for ransomware and other Notification Events requires a mature incident response capability with a clear determination process
- Annual certification by the Senior Governing Body and CISO creates executive accountability that board members and senior leaders must understand
- Third-party service provider requirements (Section 500.11) extend Part 500's reach through the supply chain
- Small entities meeting applicable thresholds may qualify for exemption from most requirements, but must file a notice of exemption with NYDFS

8. Enforcement: What Happens When Things Go Wrong

NYDFS has demonstrated a willingness to use its enforcement authority under Part 500 aggressively. Notable enforcement actions have resulted in multi-million dollar penalties for failures including: inadequate cybersecurity programs; failure to conduct adequate risk assessments; failure to report cybersecurity events within the required timeframe; and failure to implement multi-factor authentication.

In assessing penalties, NYDFS considers: the nature and severity of the violation; the extent of harm caused to customers or the financial system; the covered entity's cooperation with the investigation; the covered entity's history of compliance or violations; and the remediation steps taken. Consent orders often require the covered entity to retain an independent monitor or consultant to oversee remediation.

9. Class A Companies: Enhanced Requirements

The 2023 amendments introduced enhanced requirements for 'Class A companies' — covered entities with either at least 2,000 employees (including affiliates) or over \$1 billion in gross annual revenue. Class A companies are subject to additional requirements including:

- Independent audit of the cybersecurity program at least annually
- Privileged access management (PAM) solutions to manage privileged accounts

- Endpoint detection and response (EDR) solutions to monitor anomalous activity on endpoints
- Centralized logging systems with capacity to collect and analyze logs from across the organization
- Monitoring systems to detect and alert on cybersecurity events

10. Part 500 and Other Cybersecurity Frameworks

Framework	Relationship to Part 500
NIST Cybersecurity Framework (CSF)	Strongly aligned — Part 500 organizes cybersecurity program functions around the CSF's Identify/Protect/Detect/Respond/Recover structure. Organizations using NIST CSF as their primary framework will find significant overlap with Part 500 requirements.
ISO 27001	Complementary — ISO 27001 certification demonstrates a mature ISMS that addresses many Part 500 requirements, but does not satisfy all of them. For example, the 72-hour notification requirement and annual certification to the Superintendent are unique to Part 500 and must be addressed regardless of ISO 27001 status.
SOC 2 (AICPA Trust Services Criteria)	Complementary — SOC 2 controls address many Part 500 requirements, particularly in access control, change management, and incident response. However, Part 500's specific requirements around third-party management, MFA, encryption, and notification are additional obligations beyond what a SOC 2 report demonstrates.
HIPAA Security Rule	For covered entities that are also HIPAA-covered entities or business associates, there is significant overlap between Part 500 requirements and HIPAA Security Rule requirements. Organizations should map requirements across both frameworks to avoid duplicating compliance effort.